Governed AI Analytics Copilot

Product Requirements Document · v1, approved by Alex Sanginov on 10/7/2026; v1.1 updated 10/8, see change log

Palo Alto Networks Customer Analytics × Team ALTO PALS (Pursuit L3) · Prepared 10/6/2026 for Alex Sanginov · Demo Day 11/9/2026

This draft reflects our 10/5 discovery call. Where we made an assumption, it is marked as one, so it is easy to correct.

1. Problem

Account teams and executives at Palo Alto Networks rely on certified dashboards. When they have a follow-up question, they take a screenshot and chase an answer over email or Slack. An AI assistant could answer instantly, but large language models are probabilistic and struggle with hard numbers: **the same question phrased three different ways can return three slightly different numbers.** Different numbers for different roles are expected (a rep should only see their territory); different numbers for the same role and the same question are not.

Account teams also cover many accounts (often 10 to 100 per person) and miss timely signals, such as an executive at an account engaging with Palo Alto Networks content or a customer opening an urgent support ticket. Impact (adapted from Alex's model, 10/7): every department has at least 3–5 analysts who spend much of their time stitching data together, and a tool that does the heavy lifting lets them focus on decisions. For Demo Day we estimate departments × 3–5 analysts × about 2,000 work hours a year × the share of time spent on manual data stitching, an assumption shown as a range (20 to 40%).

2. Goals and non-goals

Goals

- **Consistent answers:** for a given role, semantically equivalent questions in the approved golden phrasing set return the same governed metric and number for the same snapshot, and ambiguous questions trigger clarification rather than a guess. Only the wording of the answer may differ.
- **Copilot next to the dashboard:** answer a question and any number of follow-ups (for example a regional breakdown that isn't on the dashboard), with a chart.
- **Role-scoped and explained:** each person sees only their data, and every answer states the metric definition and scope it used.
- **Personal, actionable alerts:** each user chooses their triggers, frequency and channel.
- **Secure by design:** resists prompt injection and social engineering, and is prepared for

third-party infosec review, with documented controls, automated scans and evidence.

- **Repeatable:** deploys from the repo on a new dataset with documented steps.

Non-goals for Demo Day

- Real Palo Alto Networks data or real SSO (we use public and synthetic data and mock identities).
- Replacing dashboards; the copilot sits alongside them.
- Every alert channel and every role at once; we start small and expand.
- Enterprise-scale load testing.

3. Users

Role	Why they matter	Demo Day scope
Technical seller / solution consultant (primary)	Lives "between two worlds," pre-sale and post-sale; sees signals both sides need	Full: copilot and alerts
Core sales rep / account owner	Builds relationships across many accounts; needs timely engagement signals	Copilot scoping and one alert type
Customer success manager	Drives deployment and adoption after the sale	Stretch: alert types defined, built if time allows
Metric steward (admin)	Owns official metric definitions	Edits definitions through a reviewed, version-controlled registry (no runtime UI editing)

4. Key user stories

- As a technical seller, I ask "what is my pipeline coverage?" in any wording and always get the same number, with the definition and scope shown.
- As a technical seller, I follow up with "which region has the least coverage?" and get a breakdown and chart even though the dashboard doesn't show it.
- As a technical seller, I get an alert when one of my customers opens a high-severity support ticket, so I can reach out before renewal is at risk.
- As a sales rep, I get an alert when an executive (CXO) at one of my accounts downloads a white paper or engages with a campaign.
- As any user, I choose which alerts I get, how often (for example weekly or monthly) and where

(Slack or email), and I never see another person's accounts.

- As a metric steward, I define a metric once and every answer and alert uses that definition.

5. Requirements

Part 1: Analytics copilot

ID	Requirement	Priority
A1	**Metric registry:** each metric defined once (formula, filters, grain, owner, version). Demo Day set of three governed metrics: open pipeline, pipeline coverage and open opportunity count, with win rate added only if the first three are stable. Views like coverage by region are saved views of these, not new formulas.	Must
A2	**Intent normalization:** the AI maps any phrasing to a registry metric plus filters. It never writes its own math or SQL. Ambiguous phrasing gets a clarifying question, not a guess (for example, total vs. weighted coverage, or no time period).	Must
A3	**Role-based scope enforced below the AI**, in the query and database layer, so a manipulated prompt still cannot return out-of-scope rows.	Must
A4	**Scope statement** on every answer: metric, definition version, filters, role scope, data timestamp.	Must
A5	**Follow-up questions:** no fixed limit on follow-up turns (per Alex, 10/7). There is no fixed user-facing turn limit, but the system retains only a bounded structured conversation summary (earlier normalized intents), never raw result rows or unrestricted chat history; every turn is re-validated and re-scoped like a new question, so a long chat cannot widen scope.	Must

A6	**Charts:** pick a sensible chart for the answer shape.	Should
A7	**New dataset onboarding:** profile a tabular dataset, propose metrics, a human confirms, then it's queryable.	Should (proves repeatability)
A8	Clearly label anything outside the registry as exploratory and unverified.	Could
A9	**Context layer:** (per Alex, 10/7) one versioned catalog of the data dictionary, business glossary and synonyms, business rules (fiscal quarter, what counts as open, region mapping, CXO definition) and metric logic. Built as an extension of the metric registry, in the same versioned files, so its synonyms also power intent normalization (A2). The intent model and the UI read it; the intent model never sees raw business rows, entitlement lists or credentials; narrative generation receives only authorized, already-aggregated results and provenance.	Must

Part 2: Actionable alerts

ID	Requirement	Priority
L1	**Rule-based signal alerts** defined in a separate, versioned alert-rule catalog over event data (support cases and CXO engagement are events, not analytics metrics).	Must
L2	**Starting trigger catalog:** high-severity support ticket on my account (technical seller); CXO engagement with content or a campaign (sales rep); large deal over $1M closes, and low product usage 6 months after purchase (CSM;	Must: technical-seller and sales-rep triggers Stretch: CSM triggers (do not block the core alerts)

	thresholds to confirm).	
L3	**User preferences:** each user picks triggers, frequency (real-time, weekly or monthly digest) and channel. Critical support cases can bypass the digest according to an explicit user or policy setting.	Must
L4	**Private routing:** one shared rule, evaluated per user through role-based access, with permissions checked again immediately before each delivery; no alert ever reveals another user's accounts.	Must
L5	**Channels:** Slack and email first; others later.	Must: one channel; Should: both
L6	Alert explains why it fired and links to the copilot for follow-up questions.	Should

Security and governance

ID	Requirement	Priority
S1	**Prompt-injection defenses:** direct injection, and indirect injection hidden in links or documents. Retrieved content is treated as data, never as instructions. The product never automatically fetches or obeys instructions from user-supplied links.	Must
S2	**Social-engineering defenses:** emotional pleas ("I'll get fired") and fake authority ("I'm the new CEO") or a role claimed mid-conversation or gradual escalation in a long chat cannot change a user's scope. Role comes from identity, never from the prompt.	Must
S3	**Detection and response:** suspicious prompts are flagged, logged, and repeated attempts can lock the session.	Should
S4	**Audit log:** user, question hash or redacted text (raw prompt text not retained by default), normalized intent, metric version, filters, data snapshot and result hash. No raw rows stored.	Must

S5	**Repo hygiene for infosec review:** dependency and vulnerability scanning, static analysis, secret scanning, protected code reviews and pinned dependencies.	Must
S6	**Red-team test suite** run in CI, including the scenarios above.	Must

Data

No internal Palo Alto Networks data. We use a public, Salesforce-style CRM sample, kept simple, plus synthetic tables needed for the alerts:

Object	Key fields	Source
Accounts	Name, location/region, employee count, public or private, website, revenue, Fortune 500 / Global 2000 tags	Public CRM sample
Opportunities	Account, region/theater, product, created date, close date, stage, amount	Public CRM sample
Contacts	Account, title (for example CXO), role	Public CRM sample
Engagement events	Contact, content or campaign, date	Synthetic (assumption)
Support cases	Account, severity, opened date, status	Synthetic (assumption)
Product usage	Account, product, consumption %, purchase date	Synthetic, stretch
Quotas	Owner, region, period, quota amount (needed for pipeline coverage = open pipeline / quota)	Synthetic (assumption)
Users and account teams	User, role (technical seller, account owner, regional manager), territory/region, account-access mappings, account owner and technical seller IDs; every data load records a snapshot ID and load timestamp	Synthetic, mock identities

6. Success criteria (tested in CI)

Criterion	How we measure it
Consistency	Semantically equivalent questions in the committed golden phrasing set (10 to 20 per metric) return the same governed metric and number for the same role and snapshot (target: 100%, valid for the fixed golden set only). Ambiguous phrasings return a clarifying question, never a number. A 10-turn follow-up chat returns the same governed numbers as asking each question fresh and stays in the user scope
Governance	Zero out-of-scope rows across answers, charts and alerts in a role-by-question access matrix
Correctness	Answers match hand-computed values on a fixed data snapshot
Security	Red-team suite passes: injection, social engineering, impersonation and poisoned links, a role claimed mid-chat and gradual scope escalation are all blocked and logged
Alert quality	Planted events fire the right alert to the right user only, at the chosen frequency
Repeatability	Documented onboarding steps are exercised against a second synthetic fixture if core governance and alerts are complete
Explainability	Every answer shows its definition and scope

7. Priorities

Never cut: consistency across phrasings, role scoping below the AI, the audit log, and the red-team suite. If scope must shrink, as Alex suggested, we document the assumption and cut from the bottom of the Should and Could items first. Timing, milestones and the cut order live in the separate Roadmap document.

8. Assumptions and questions for Alex

Confirmed with Alex (10/5 call and 10/7 email)

- The technical seller (solution consultant) is the primary persona for Demo Day.
- No internal Palo Alto Networks data; a public Salesforce-style CRM sample, kept simple (Accounts, Opportunities, Contacts).
- The code lives in our GitHub and goes through Palo Alto Networks infosec review.
- Weekly updates by email on Mondays, with a call only when needed (Alex, 10/7). PRD and

roadmap approved by Alex on 10/7.

- If scope is too big, we document our assumptions and reduce scope.

Our working assumptions

- Synthetic engagement, support-case, product-usage, quota and account-team tables are acceptable for alert signals, since the CRM sample does not include them.
- Slack and email are acceptable alert channels for the demo.
- "Low usage" means consumption still around 10–20% six months after purchase. This is a stretch CSM trigger and does not block the core technical-seller alerts.

Questions for Alex

- Is it OK to use synthetic data for the alert signals?
- What exact threshold should define "low usage"?
- Are there AI providers Palo Alto Networks prefers or does not allow, or rules about where data can be processed?
- May we mention Palo Alto Networks by name at Demo Day?

9. Change log

10/6: v1 drafted from the 10/5 discovery call.
10/7: Alex approved v1. Added A5 (follow-ups with no fixed limit), A9 (context layer), email cadence and his impact model.
10/8 (v1.1): after team review: quota and account-team data tables; context layer built inside the registry files; ambiguity and long-conversation tests; mid-chat role and gradual-escalation red-team cases; impact labeled as adapted, with the time share as a 20 to 40% assumption; repeatability met by a documented script; answered questions moved out of the open list; scope set to 3 governed metrics (win rate only if they are stable). Second team review: golden-set consistency wording, bounded conversation summary, infosec-review readiness, what the model can see, identity and snapshot data, versioned alert-rule catalog, send-time permission re-check, audit retention, critical-alert digest bypass, no link fetching, measurable repo controls.